DE POC EN GOOGLE AI STUDIO A RELEASE CANDIDATE EN ANTIGRAVITY

# Aseguramiento, Auto-Auditoría y Economía FinOps en GenAI

Cómo **AegisAI Enterprise** fue prototipado en **Google AI Studio (Gemini 3.6 Flash)**, diseñado con **Gemini 3.1 Pro (5%)**, construido a escala en **Google Antigravity (Gemini 3.8 Flash — 80% combinado en Flash)**, auto-auditado (68.9% ➔ 97.8%), endurecido y verificado en QA con **Gemini 4.0 Argon (10%)** y **Claude Opus 5.5 Max (5%)**, y presentado como Release Candidate ante **Farmacias del Ahorro**, **Asociación Mexicana de Franquicias** y **Grupo Coppel**—con una inversión total de **$215.24 USD** ($319.80 c/ bucles agénticos).

1. POC EN AI STUDIO (GEMINI 3.6 FLASH)
2. ARQ. (3.1 PRO 5%) + CONSTRUCCIÓN (3.8 FLASH 74%)
3. HARDENING Y QA (4.0 ARGON 10% + OPUS 5.5 5%)
4. RC: FARMACIAS DEL AHORRO • AMF • COPPEL
5. COSTO POR AUDITORÍA: $0.43–$1.55 (BATCH: $0.21) VS $8.55–$31.09
6. COSTO TOTAL DE CREACIÓN: $215.24 USD

CICLO DE VIDA DE INGENIERÍA MULTI-MODELO DE EXTREMO A EXTREMO

# Cómo Construimos, Auto-Auditamos y Validamos AegisAI

Un recorrido de ingeniería multi-modelo en cuatro etapas (80% Flash • 10% Argon • 5% 3.1 Pro • 5% Opus 5.5 Max).

FASE 1 • PRUEBA DE CONCEPTO (~6% TOKENS)

## 1. Prototipado en Google AI Studio (Gemini 3.6 Flash — $6.53)

• Se construyó la Prueba de Concepto inicial en **Google AI Studio** utilizando **Gemini 3.6 Flash** (~45 iteraciones, 4.20M In / 0.90M Out tokens @ tarifa oficial $0.75/$3.75).
• Se validó la generación estructurada bajo JSON Schema, la ingesta multimodal de PDFs/diagramas y la interfaz inicial en React.
• Demostró que los modelos Flash con temperatura `0.0` evalúan controles complejos en segundos.

FASE 2 • ARQUITECTURA (5%) Y CONSTRUCCIÓN (74%)

## 2. Arquitectura en 3.1 Pro ($14.06) y Build en 3.8 Flash ($70.65)

• **Arquitectura (Gemini 3.1 Pro, 5%):** Diseño de topología Zero-Trust de 4 capas, motor Map-Reduce de 12 lotes, taxonomía de 265 controles y aislamiento Firestore (3.55M In / 0.58M Out @ $2.00/$12.00).
• **Construcción Masiva (Gemini 3.8 Flash, 74%):** Más de **171 prompts** en **Google Antigravity** construyendo Express/React 19, GCP Live Scanner, 17 manuales PDF ($65.85) y auto-auditorías en vivo ($4.80). Familia Flash = **80% de tokens por $77.18** ($38.59 Batch).

FASE 3 • AUTO-AUDITORÍA, HARDENING (10%) Y QA (5%)

## 3. Auto-Auditado (68.9%➔97.8%) + Endurecido en Argon y Opus 5.5

• La auto-auditoría base ( `MULTI-2026-0437` ) sobre `Originaldocs.zip` obtuvo **68.9%** (35 brechas).
• **Gemini 4.0 Argon (10%, $25.70):** Vertex AI ADC sin llaves, perímetro Cloud IAP, 308 pruebas Firestore y diagramas 4K/8K (7.10M In / 1.15M Out @ $2.00/$10.00).
• **Claude Opus 5.5 Max (5%, $96.45):** Revisión red-team adversarial, auth en tiempo constante, filtros SSRF/DNS y QA ➔ **97.8%** ( `MULTI-2026-8983` , 0 fallos).

FASE 4 • VALIDACIÓN EMPRESARIAL

## 4. Presentación de Release Candidate (RC) a Líderes en México

• Presentamos el Release Candidate (RC) endurecido ante tres organizaciones líderes:
1. **Farmacias del Ahorro** (Salud y Retail Farmacéutico)
2. **Asociación Mexicana de Franquicias (AMF)** (Ecosistema de Franquicias)
3. **Grupo Coppel** (Servicios Financieros y Retail Omnicanal)

• Se validó el cumplimiento simultáneo de OWASP AI-SVS, ISO 42001, LFPC y LFPDPPP.

VERIFICACIÓN EN BUCLE CERRADO ("DOGFOODING")

# Auditando el Código y Manuales de AegisAI con AegisAI

Cómo AegisAI diagnosticó 35 brechas de OWASP AI-SVS e ISO 42001 en su propio prototipo y guió su remediación hasta 97.8%.

## 1. Auto-Auditoría Base ( `MULTI-2026-0437` )

- **Puntaje Global:** 68.9% (Nivel L2)
- **OWASP AI-SVS v1.0:** 71.8% (17 brechas)
- **ISO/IEC 42001:2023:** 66.7% (18 brechas)
- **Hallazgos Detectados por AegisAI:**
  - Directorio `/app/config` escribible ( `C04.1` )
  - Comparación `===` vulnerable a timing ( `C05.3` )
  - Rol `roles/viewer` en SA de ejecución ( `C05.2` )
  - Falta de manifiesto SHA-256 ( `C01.4` )
  - Falta de Manual AIMS ISO 42001 y canal ético

## 2. Remediación Integral en Antigravity

- **Generador:** Recetario Sección 4 sin truncar (los 35 parches completos), corte por oración completa y detección precisa de lenguaje.
- **Contenedor y Cloud:** `chmod -R a-w /app` ( `C04.1` ), Cloud IAP + bloqueo SSRF/IMDS ( `C04.3` ), revocación de `roles/viewer` ( `C05.2` ).
- **Guardrails:** Manifiesto SHA-256 ( `C01.4` ), detector crescendo ( `C02.10` ), `crypto.timingSafeEqual` ( `C05.3` ), cuotas Anti-DoW ( `C11.1` ), sagas ( `C09.4` ).
- **Manuales y Reglas:** Manual 8 AIMS ISO 42001 y 308/308 pruebas de reglas Firestore aprobadas.

## 3. Re-Auditoría Post-Fix ( `MULTI-2026-8983` )

- **Puntaje Global:** 97.8% (+28.9 pts)
- **ISO/IEC 42001:2023:** 100.0% (54/54 controles aprobados, **0 Fallidos**)
- **OWASP AI-SVS v1.0:** 94.7% (45/49 aprobados, **0 Fallidos**)
- **Telemetría Real en Firestore:**
  - Modelo: `gemini-3.8-flash` en Vertex AI
  - Tokens de Entrada: `1,758,724`
  - Tokens de Salida: `100,715`
  - Cero controles fallidos restantes

**Valor del Bucle de Auto-Auditoría:** Ejecutar AegisAI contra su propia documentación demostró que el motor no alucina aprobaciones: detectó vulnerabilidades sutiles de código y gobernanza, generó las recetas de corrección y certificó el 97.8% tras aplicar los cambios.

VALIDACIÓN DE MERCADO Y ROADSHOW EJECUTIVO

# Presentación del Release Candidate (RC) a Líderes en México

Tras completar el endurecimiento por auto-auditoría, presentamos el Release Candidate ante tres organizaciones estratégicas.

SALUD Y RETAIL FARMACÉUTICO

## Farmacias del Ahorro

• **Enfoque del Caso de Uso:** Auditoría de asistentes digitales farmacéuticos, orientación clínica y atención omnicanal con IA.
• **Capacidades Clave Demostradas:**
– Protección estricta de datos sensibles de salud/PII bajo la **LFPDPPP** y enmascaramiento DLP pre-inferencia.
– Mitigación de alucinaciones ( `temperature: 0.0` ) y escalamiento a revisión humana ( `ISO 42001 A.5.2` ).
– Telemetría continua de citación y anclaje RAG ( `C08.4` ) en Vertex AI.

ECOSISTEMA NACIONAL DE FRANQUICIAS

## Asociación Mexicana de Franquicias

• **Enfoque del Caso de Uso:** Estandarización de gobernanza de IA, chatbots comerciales y publicidad automatizada en redes de franquicias.
• **Capacidades Clave Demostradas:**
– Cumplimiento **LFPC (Profeco 2026)**: prevención de patrones oscuros y retracto comercial de 5 días (Art. 56).
– **Motor BYOF:** Marcos normativos propios para franquicias con auditorías Flash de bajo costo ( `$0.43 USD` estándar o `$0.21 USD` en Batch).

SERVICIOS FINANCIEROS Y RETAIL

## Grupo Coppel

• **Enfoque del Caso de Uso:** Modelos de riesgo crediticio, prevención de fraude transaccional y gobernanza corporativa de GenAI a gran escala.
• **Capacidades Clave Demostradas:**
– Certificación simultánea **OWASP AI-SVS v1.0 (Nivel L2/L3) + ISO/IEC 42001:2023**.
– Aislamiento multi-inquilino por dominio ( `C05.4` , `C08.1` ), borde Cloud IAP Zero-Trust y **GCP Live Scanner** sin llaves.
– Generación de arquitectura remediada y recetario Terraform/TypeScript.

**Impacto en las Presentaciones RC:** Los comités directivos destacaron la capacidad única de AegisAI para unificar **estándares globales (OWASP AI-SVS + ISO 42001)** con **legislación mexicana (LFPDPPP + LFPC)** entregando código listo para producción en minutos.

ANÁLISIS FINOPS: COSTO POR AUDITORÍA COMPLETA OWASP AI-SVS + ISO/IEC 42001

# Gemini (3.8 Flash, 4.0 Argon, 3.1 Pro) vs. Claude (Fable 5.1, Opus 5.5)

Calculado con telemetría real de tokens en Firestore bajo Tarifas Oficiales 2026 por auditoría dual completa.

**AUDITORÍA ESTÁNDAR (3.8 FLASH)**
**$0.43 USD** — 1.0X BASE
Nivel Batch/Flex: **$0.21 USD**

**SUITE 10 PDFS (3.8 FLASH)**
**$1.55 USD** — 12 LOTES
1.64M In + 86.5K Out (**$0.78 Batch**)

**VENTAJA VS. OPUS 5.5 MAX**
**20.0x Menor** — VERIFICADO
**40.0x** vs Batch • **6.7x** vs Opus Est.

**AHORRO OPEX MENSUAL (1K AUD.)**
**95.0% Ahorro** — -$8,122/MES
**$428/mes** vs. $8,550/mes (Opus Max)

## Benchmark de Costo por Auditoría y Multiplicador (USD)

Gráfica Dual: Auditoría Estándar (370K In / 40K Out) vs. Suite 10 PDFs (1.64M In / 86.5K Out)

Aud. Estándar · Suite 10 PDFs

**Gemini 3.8 Flash** — MOTOR BASE — $0.75 In / $3.75 Out — 1.0X BASE
Est: $0.43 (Batch $0.21)
10-PDF: $1.55 ($0.78)

**Gemini 4.0 Argon** — FRONTIER — $2.00 In / $10.00 Out — 2.67X VS FLASH
Est: $1.14 USD
10-PDF: $4.15 USD

**Gemini 3.1 Pro** — RAZONAMIENTO — $2.00 In / $12.00 Out — 2.78X – 2.85X
Est: $1.22 USD
10-PDF: $4.32 USD

**Claude Fable 5.1 Medium** — EXTERNO — $3.00 In / $15.00 Out — 4.0X (8.0X VS BATCH)
Est: $1.71 USD
10-PDF: $6.22 USD

**Claude Opus 5.5 Max** — NIVEL MAX — $15.00 / $75.00 (Est: $5/$25) — 20.0X (40X BATCH / 6.7X EST)
Est: $8.55 (Est $2.85)
10-PDF: $31.09 ($10.36)

## Gasto Mensual @ 1,000 Auditorías / Mes

AHORRA $8,122 / MES

Factura mensual de inferencia por 1,000 auditorías estándar multi-norma




## Telemetría Real de Tokens (Cloud Firestore)

15 Llamadas Map-Reduce / Aud.

**Perfil A: Auditoría Estándar de Arquitectura (408.6K tok)** — 90.3% In / 9.7% Out

Auditorías MULTI-2026-0507 y 1250 : Promedio 368,827 Entrada + 39,812 Salida

**Perfil B: Suite Completa 10 PDFs (1.725M tok)** — 95.0% In / 5.0% Out

Auditorías MULTI-2026-0437 y 8983 : Promedio 1,638,410 Entrada + 86,495 Salida (~136K ctx/lote)



Fuente de Telemetría: Cloud Firestore (aegis-ai-db) Auditorías MULTI-2026-0437, 8983, 0507 y 1250

ROI DE INGENIERÍA Y DESGLOSE MULTI-MODELO (80% FLASH • 10% ARGON • 5% PRO • 5% OPUS)

# Cuánto Dinero Gastamos Creando AegisAI: $215.24 USD en Total

Ingeniería multi-modelo optimizada entre PoC en AI Studio, Arquitectura de Sistema, Construcción Full-Stack, Hardening y QA Adversarial.

**$215.24**
Inversión Total Realizada creando AegisAI ($319.80 c/ bucles agénticos)

**~71.0M**
Tokens de Entrada Totales (80% Flash por $77.18 • 10% Argon • 5% Pro • 5% Opus)

**$1,931**
Lo que cuesta el mismo volumen si se ejecuta 100% en Claude Opus 5.5 Max

**~$95,000**
Costo equivalente de desarrollo tradicional (4 ingenieros DevSecOps × 3 meses)

| Fase y Rol en el Ciclo | Modelo y Participación | Alcance de Ingeniería y Tokens | Gasto Real (2026) | Si 100% Opus 5.5 |
|---|---|---|---|---|
| **1. PoC Rápido y Esquemas JSON** | AI Studio • `Gemini 3.6 Flash` (~6%) | ~45 iteraciones PoC, JSON schema y PDFs • 4.20M In / 0.90M Out | **$6.53 USD** | $130.50 USD |
| **2. Arquitectura y Diseño Base** | Antigravity • `Gemini 3.1 Pro` (5%) | Topología Zero-Trust, Map-Reduce 12 lotes, 265 controles • 3.55M In / 0.58M Out | **$14.06 USD** | $96.45 USD |
| **3. Construcción, Manuales y Auditorías** | Antigravity + Vertex • `Gemini 3.8 Flash` (74%) | 171 prompts, 17 PDFs ($65.85) + Auto-Auditorías ($4.80) • 52.60M In / 8.32M Out | **$70.65 USD** | $1,412.70 USD |
| **4. Hardening Profundo y Diagramas** | Antigravity • `Gemini 4.0 Argon` (10%) | Vertex ADC sin llaves, Cloud IAP, 308 tests Firestore, 4K • 7.10M In / 1.15M Out | **$25.70 USD** | $192.90 USD |
| **5. Bugfixing Adversarial y QA** | Antigravity • `Claude Opus 5.5 Max` (5%) | Red-team cruzado, auth tiempo constante, filtros SSRF/DNS • 3.55M In / 0.58M Out | **$96.45 USD** | $96.45 USD |
| **6. Infraestructura Serverless GCP** | Cloud Build (9x), Cloud Run, Firestore, IAP | 9 builds de contenedor, Cloud Run scale-to-zero, `aegis-ai-db` • **Total: $215.24 USD** | **$1.85 USD** | $1.85 USD |

EL PROBLEMA A RESOLVER

# El Punto Ciego Crítico en la Adopción Empresarial de GenAI

Las organizaciones despliegan modelos generativos, flujos agénticos, herramientas MCP y pipelines RAG sin verificación arquitectónica ni gobernanza ISO 42001.

### ⚠ Brechas de Acceso y Despliegue sin Gobierno

Según **IBM Cost of a Data Breach 2025**, el **13% de las organizaciones** sufrió brechas en modelos o aplicaciones de IA, y el **97% de ellas** carecía de controles de acceso adecuados o Evaluación de Impacto ( `ISO 42001 A.5.1` ).

### ⚠ Superficie Multi-Turno y Agéntica

Pipelines RAG, servidores MCP y agentes introducen vectores críticos: **Inyección Multi-Turno Crescendo** ( `C02.10` ), **Envenenamiento Normativo/Vectorial** ( `C01.4` ) y SSRF/IMDS ( `C04.3` ).

### ⚠ Silo entre CISO y Ciencia de Datos

Los equipos de seguridad carecen de herramientas para auditar grafos de agentes, manifiestos MCP ( `C10.1` ) y ACLs vectoriales ( `C08.1` ) antes de producción.

### Brecha de Gobernanza Operativa (ISO/IEC 42001)

Dificultad para operacionalizar los controles de **ISO/IEC 42001:2023** —como Políticas Corporativas de IA ( `A.2.1` ), Canal Ético Confidencial ( `A.3.3` ), Inventario de Activos IA ( `A.4.1` ) y Apelación Humana ( `A.5.2` )— en el ciclo de ingeniería.

### Proliferación de "Shadow AI" y Denial of Wallet

Invocaciones externas sin cuotas, comparación insegura de tokens ( `C05.3` ), cuentas de servicio sobre-privilegiadas ( `C05.2` ), falta de presupuestos Anti-DoW ( `C11.1` ) y exposición de logprobs ( `C11.4` ).



Fuente: OWASP GenAI Security Project (AI-SVS v1.0) & ISO/IEC 42001:2023

MATRIZ DE CUMPLIMIENTO

# Soporte Multi-Estándar y Gobernanza AIMS ISO/IEC 42001

Evaluación simultánea de estándares técnicos globales de seguridad en IA, sistemas de gestión y leyes de privacidad.

| Estándar / Marco | Alcance Técnico y de Gobernanza | Controles Clave Verificados y Aplicados por AegisAI | Nivel |
|---|---|---|---|
| **OWASP AI-SVS v1.0** | Estándar de Verificación de Seguridad en IA (12 Capítulos) | `C01.4` Manifiesto SHA-256, `C02.10` Guardia Crescendo, `C04.1` Contenedor Read-Only, `C04.3` Cloud IAP y Bloqueo SSRF, `C05.2–C05.4` Auth en Tiempo Constante e IAM, `C08.1/C08.4` ACLs RAG, `C09.4` Sagas, `C10.1–C10.5` Seguridad MCP, `C11.1/C11.4` Anti-DoW y Logprobs Off, `C12.2` Alertas SIEM. | L1 / L2 / L3 LISTO |
| **ISO/IEC 42001:2023** | Sistema de Gestión de IA (AIMS Cláusulas 4–10 y Anexo A) | `Cláusula 4.1/4.2` Contexto y Stakeholders, `Cláusula 5/A.2.1/A.2.3` Política Corporativa IA, `Cláusula 7/A.3.3` Competencia y Canal Ético, `A.4.1` Inventario IA, `A.5.1–A.5.3` Evaluación de Impacto y Apelación Humana, `Cláusula 9` KPIs y Auditoría Interna, `A.9.1/A.9.2` Uso Aceptable. | CERTIFICACIÓN LISTA |
| **Regulación Mexicana (2026)** | Protección al Consumidor (LFPC) y Datos Personales (LFPDPPP) | Transparencia algorítmica, prevención de patrones oscuros, retracto de 5 días (Art. 56 LFPC), purga en cascada ARCO y enmascaramiento DLP. | ESTATUTARIO LOCAL |
| **Marco BYOF Personalizado** | *Bring Your Own Framework* (Multi-Inquilino) | Ingesta autenticada por administrador ( `C05.3` ) con verificación SHA-256 ( `C01.4` ) y pre-filtrado ACL por dominio de inquilino ( `allowedDomains` , `C08.1` ). | AISLADO POR TENANT |

**Motor Map-Reduce Cruzado sin Colisiones:** Evalúa más de 103 controles combinados de OWASP AI-SVS e ISO/IEC 42001 en lotes paralelos usando enums de capítulo restringidos para que las Cláusulas 9/10 y Anexo A.9/A.10 jamás colisionen con C09/C10.

ARQUITECTURA DE SOFTWARE

# Arquitectura Zero-Trust de 4 Capas y Defensa en Profundidad

Arquitectura serverless endurecida en Google Cloud Run detrás de Identity-Aware Proxy (IAP) con inferencia Vertex AI sin llaves.

### 1. Perímetro y SPA

- **Cloud IAP** ( `--no-allow-unauthenticated` )
- **React 19 + TS + Vite**
- Lista blanca OAuth 2.0 en Firebase Auth ( `google.com` , `altostrat.com` )
- Avisos visibles ISO 42001 de Política, Apelación ( `A.5.2` ) y Canal Ético ( `A.3.3` )

### 2. Capa API Endurecida

- **Contenedor Read-Only** ( `chmod -R a-w /app` , `C04.1` )
- Tokens en tiempo constante ( `crypto.timingSafeEqual` , `C05.3` )
- Firebase Admin `verifyIdToken()`
- Guardia DNS Rebinding ( `C10.5` ) y Firma MCP ( `C10.1` )
- Cuotas Anti-DoW ( `C11.1` )

### 3. Motor IA y Guardrails

- **Vertex AI** ( `gemini-3.8-flash` ) vía ADC sin llaves
- SA de mínimo privilegio ( `aegis-runner-sa` : cero `roles/viewer` , `C05.2` )
- Detector Multi-Turno Crescendo ( `C02.10` )
- `responseLogprobs: false` ( `C11.4` )
- Bloqueo SSRF/IMDS ( `C04.3` )

### 4. Datos, Integridad y Sagas

- **Cloud Firestore** ( `aegis-ai-db` ) vía Admin SDK
- 308/308 pruebas `firestore.rules`
- Auditorías inmutables ( `allow delete: if false` ) y ACLs `ownerUid` ( `C05.4` )
- Manifiesto SHA-256 ( `C01.4` )
- Sagas Compensatorias ( `C09.4` )

### Aislamiento Zero-Trust y Alertamiento Estructurado de Seguridad (C12.2):

El estado en tiempo de ejecución se persiste exclusivamente en Firestore ( `system_config/admin_settings` ) y caché efímero `/tmp/aegis-runtime-cache` . Cada evento de seguridad emite una alerta JSON estructurada ( `aegis-security-alerting-c12-2` ) hacia Google Cloud Logging.

EJECUCIÓN OPERATIVA

# Flujo del Auditor: De la Ingesta al Blindaje al 100%

Ciclo determinístico de aseguramiento en 6 etapas con supervisión humana integrada y remediación automatizada.

1. **Ingesta Autenticada y Guardrails Pre-Vuelo**
   El usuario corporativo (verificado por Cloud IAP + Firebase ID Token) carga PDFs/ZIPs; `inspectPromptAndTrackSession` ( `C02.10` ) y DLP sanean la entrada.

2. **Contexto Verificado SHA-256 y Filtrado por Tenant**
   Se validan los snapshots normativos contra `integrity-manifest.json` ( `C01.4` ) y se filtran los marcos por `tenantDomain` ( `C08.1` ).

3. **Evaluación Determinística Map-Reduce en Vertex AI**
   `gemini-3.8-flash` ( `temperature: 0.0` , `responseLogprobs: false` , timeout 180s) evalúa cada lote bajo enums estrictos de capítulos.

4. **Tablero Ejecutivo y Apelación Humana (ISO A.5.2)**
   Gráficos radar interactivos, madurez L1/L2/L3 y flujo directo de Apelación de Dictamen / Revisión Humana ( `ai-appeals@aegisai.enterprise` ).

5. **Arquitectura Remediada al 100% y Recetario Completo**
   Sintetiza la Sección 3 drop-in + Sección 4 Cookbook para todos los hallazgos `1..N` con etiquetas precisas ( `typescript` , `hcl` , `yaml` , `python` , `bash` ).

6. **Persistencia Inmutable y Saga Compensatoria**
   Guardado en Firestore con atribución `ownerUid` / `tenantDomain` ( `C05.4` ), protección `runCompensatingSaga` ( `C09.4` ) y registro de KPIs AIMS ( `C08.4` ).

TRAZABILIDAD INTEGRAL DE REMEDIACIÓN

# Controles OWASP AI-SVS v1.0 & ISO/IEC 42001:2023 Implementados

Controles arquitectónicos y de gobernanza aplicados en código, contenedor, perímetro cloud y políticas AIMS.

## Controles Técnicos OWASP AI-SVS v1.0 (17 Dominios Endurecidos)

- **C01.4 Integridad Normativa:** `verifyNormativeSnapshotsIntegrity()` con manifiesto SHA-256 al arranque.
- **C02.10 Defensa Crescendo:** `inspectPromptAndTrackSession()` bloquea escalación multi-turno (HTTP 422).
- **C04.1 & C04.3 Infraestructura:** `/app` solo lectura ( `chmod -R a-w` ), Cloud IAP, egreso VPC y bloqueo SSRF/IMDS `validateOutboundEndpoint()` .
- **C05.2, C05.3 & C05.4 Auth/IAM:** Revocación de `roles/viewer` en `aegis-runner-sa` , `crypto.timingSafeEqual` , verificación de Firebase ID token y ACLs `ownerUid` .
- **C08.1 & C08.4 RAG/Grounding:** Pre-filtrado ACL por dominio de inquilino y telemetría continua.
- **C09.4 & C10.1–C10.5 Agentes/MCP:** `runCompensatingSaga()` , firma MCP Ed25519/HMAC, OAuth 2.1 PKCE y `dnsRebindingGuard` .
- **C11.1, C11.4 & C12.2 FinOps/SIEM:** `acquireAntiDoWQuota()` , `responseLogprobs: false` y `emitSecurityAlert()` .

## Controles de Gobernanza AIMS ISO/IEC 42001:2023 (18 Cláusulas y Anexo A)

- **Cláusula 4.1 & 4.2 Contexto y Stakeholders:** Matriz de cuestiones internas/externas, rol de proveedor de aseguramiento IA y partes interesadas.
- **Cláusula 5.1, 5.2, A.2.1 & A.2.3 Liderazgo y Política IA:** Política Corporativa de IA aprobada por dirección con revisión anual.
- **Cláusula 7.2, 7.3 & A.3.3 Competencia y Canal Ético:** Capacitación por rol y canal confidencial de denuncias ( `ai-ethics-whistleblower@aegisai.enterprise` ).
- **A.4.1 Inventario de Recursos y Herramientas:** Catálogo de modelos, corpus normativos, cuentas de servicio y secretos KMS.
- **A.5.1, A.5.2 & A.5.3 Evaluación de Impacto y Apelación:** Metodología AIIA, umbrales cuantitativos y canal de apelación humana ( `ai-appeals@aegisai.enterprise` ).
- **Cláusula 9.1–9.3 & A.9.1/A.9.2 Aseguramiento y Uso:** KPIs continuos, auditoría interna semestral, revisión directiva y avisos de uso aceptable.

EVOLUCIÓN Y ROADMAP

# Siguientes Pasos en la Ingeniería de AegisAI

Hoja de ruta tras las presentaciones del Release Candidate a Farmacias del Ahorro, AMF y Grupo Coppel.

Q4 2026 • CORTO PLAZO

### Compuertas CI/CD Shift-Left

**GitHub Actions** y **GitLab CI Runners** oficiales para bloquear automáticamente *pull requests* con vulnerabilidades de prompt injection, manifiestos MCP sin firma o vectores sin cifrar.

Q1 2027 • MEDIANO PLAZO

### Auditoría de Grafos Multi-Agente

Módulo especializado para auditar flujos de agentes autónomos complejos (LangGraph, CrewAI, AutoGen): validación de fronteras de autorización, sagas compensatorias y sandboxing de memoria.

Q2 2027 • LARGO PLAZO

### Auto-Remediación con IaC

Síntesis automatizada de módulos de **Terraform** y **Helm Charts** que apliquen políticas de Cloud IAP, VPC Service Controls y Cloud Armor en un clic.

### 🎯 Conclusión: Aseguramiento Empresarial Construido por $215.24 USD Multi-Modelo, Auditando por $0.43–$1.55 USD (Batch: $0.21)

Combinando **Gemini 3.6 y 3.8 Flash (80%)** para el PoC y la construcción masiva con **Gemini 3.1 Pro (5%)** en arquitectura y **Gemini 4.0 Argon (10%) + Claude Opus 5.5 Max (5%)** para hardening profundo y QA, AegisAI se construyó con un **88.9% de ahorro frente a 100% Opus ($1,931)** y un **99.77% de ahorro frente al desarrollo tradicional (~$95k)**.



Contacto: opensource@aegis-ai.dev • GitHub: github.com/fjhuerta-67/AegisAI